Security Assessment Report

Subject: Insecure Transmission of Sensitive Data over HTTP
Date: February 25, 2026
Prepared by: Muhammad Khubaib Ahmad

---

1. Executive Summary

A security assessment of a public diagnostic laboratory web portal identified that sensitive information, including user credentials and medical reports, is transmitted over unencrypted HTTP connections. This exposes the data to interception by any party with network access.

The vulnerability represents a **critical risk** to patient privacy and confidentiality and may result in unauthorized disclosure of sensitive medical information.

---

2. Scope of Assessment

- **Target:** Public diagnostic laboratory web portal (no patient-specific data accessed)
- **Protocol Analyzed:** HTTP/1.1
- **Assessment Method:** Network traffic inspection using packet capture tools (Wireshark)
- **User Context:** Authorized personal test account only
- **Limitations:** No attempt was made to access or store data from other users.

Note: The specific laboratory is not named in this report to comply with ethical and legal standards.

---

3. Vulnerability Overview

- **Vulnerability Type:** Sensitive Data Exposure
- **OWASP Classification:** A02 – Cryptographic Failures
- **Attack Vector:** Network sniffing / Man-in-the-Middle (MITM)

The web portal fails to encrypt sensitive data during transmission, allowing attackers to intercept and reconstruct authentication credentials and medical reports.

---

4. Technical Findings

1. The web portal uses **HTTP instead of HTTPS** for login and report retrieval.

2. Authentication credentials (username and password) are transmitted in **clear text** in POST requests.
3. Medical report files (PDF) are delivered over **unencrypted HTTP responses**.
4. Captured network traffic demonstrates that sensitive content can be **reconstructed without authentication**.

This confirms the absence of proper **transport-layer encryption** for sensitive operations.

---

5. Risk and Impact Analysis

- Exposure of user credentials to network-based attackers.
- Unauthorized access to confidential medical reports.
- Non-compliance with healthcare data privacy standards and regulations.
- Potential reputational, legal, and regulatory consequences for the organization.
- Loss of user trust.

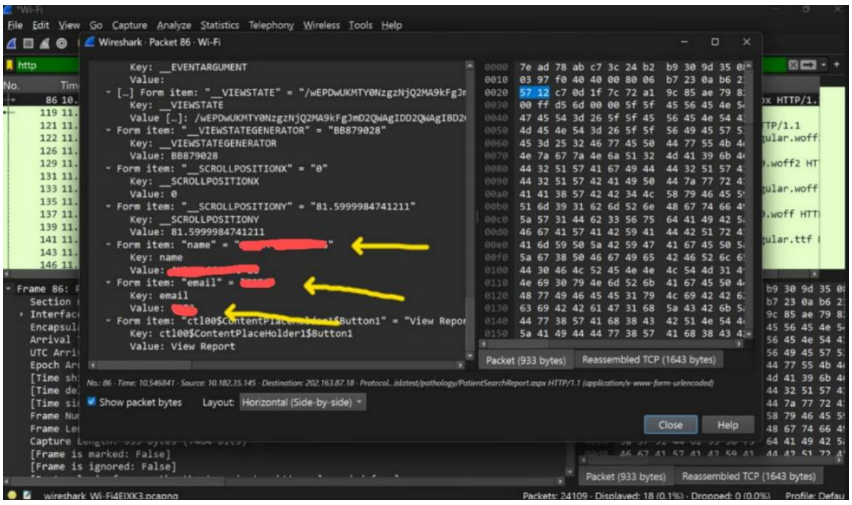
Severity Level: Critical
Justification: Vulnerability is easily exploitable and affects highly sensitive personal data.

---

6. Evidence (High-Level)

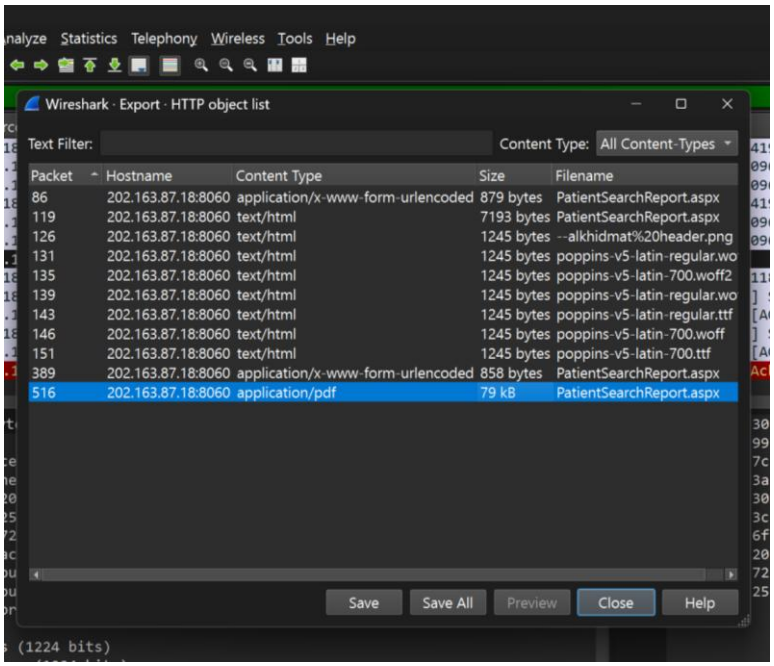
E1 – Login Credentials Transmitted over HTTP

Tool: Wireshark
Observation: HTTP POST request from the test account showing user authentication data (email and password) transmitted in clear text. Credentials are masked in the report to preserve privacy.



Caption: "Figure 1 – HTTP POST request showing user credentials transmitted without encryption."

E2 – Medical Report Delivered over HTTP
Tool: Wireshark
Observation: HTTP response contains an object of type `application/pdf`, representing the medical report delivered unencrypted. The object can be exported from Wireshark, demonstrating sensitive data exposure.



Caption: "Figure 2 – Unencrypted PDF object observed in HTTP response, representing sensitive medical report data."

Note: No patient-specific data or reports are included in this report to maintain privacy and confidentiality.

---

7. Recommendations

Immediate corrective actions:

1. Enforce **HTTPS (TLS encryption)** across all pages and APIs.
2. Redirect all HTTP traffic to HTTPS.
3. Set session cookies with **Secure** and **HttpOnly** flags.
4. Implement **HTTP Strict Transport Security (HSTS)**.
5. Conduct a full security review of data handling and transmission mechanisms.
6. Provide secure coding and data-handling training for development and IT teams.

---

8. Conclusion

The diagnostic laboratory web portal currently exposes sensitive user data through unencrypted network communication. This vulnerability poses a **critical threat** to patient confidentiality and organizational security.

Immediate remediation is recommended to align with **best security practices** and ensure protection of sensitive data.

---

9. Responsible Disclosure Statement

- Assessment conducted ethically and within authorized access.
- No patient data was collected, stored, or shared.
- Report intended solely for improving system security.